Introduction to Applied Cryptography

Thomas Peters – F.-X. Standaert

Slides 07





Key Agreement $\longrightarrow$ Symmetric Encryption

A and B agree on a key k (interactive protocol)
A can encrypt and decrypt to and from B with k

Is everything solved?

- How many keys? N parties implies $\mathcal{O}(N^2)$ keys/interactions
- How (often) do we need to update keys? New interactions
- Do we need interaction before being able to encrypt/decrypt?

From "boxes" to "padlock"

Public Key Encryption

Diffie-Hellman offers a secret key, which we can then use to encrypt messages.

Can we extend it into a full encryption scheme?

- Recipient announces a *public* encryption key
  Everyone can use it to encrypt as many messages as needed
- Recipent keeps a *secret* decryption key
  He is the only one who can decrypt.

Public Key Encryption

What are we looking for, exactly?

A triple $\langle \mathrm{Gen}, \mathrm{Enc}, \mathrm{Dec} \rangle$ of PPT algos:

- Gen probabilistically selects $(pk, sk) \leftarrow \mathrm{Gen}(1^n)$
  pk/sk are the public/private key
- Enc provides $c \leftarrow \mathrm{Enc}_{pk}(m)$
- Dec provides $m := \mathrm{Dec}_{sk}(c)$

s.t., $\exists$ negl. $\epsilon : \forall n$, $(pk, sk) \leftarrow \mathrm{Gen}(1^n)$, and $\forall m$:

$$\Pr[\mathrm{Dec}_{sk}(\mathrm{Enc}_{pk}(m)) \neq m] < \epsilon(n)$$

Assumption: $|pk| \geq n$, $|sk| \geq n$



Public Key Encryption

Security against eavesdropper

Given $\Pi := \langle \mathrm{Gen}, \mathrm{Enc}, \mathrm{Dec} \rangle$, and PPT adversary $\mathcal{A}$, define the following experiment $\mathrm{PubK}^{\mathrm{eav}}_{\mathcal{A},\Pi}(n)$:

1. Generate $(pk, sk) \leftarrow \mathrm{Gen}(1^n)$
2. $\mathcal{A}(pk)$ outputs m_0, m_1 of same length
3. Choose $b \leftarrow \{0,1\}$, and send $\mathrm{Enc}_{pk}(m_b)$ to $\mathcal{A}$
4. $\mathcal{A}$ outputs b'
5. Define $\mathrm{PubK}^{\mathrm{eav}}_{\mathcal{A},\Pi}(n) := 1$ iff $b = b'$

Difference with $\mathrm{PrivK}^{\mathrm{eav}}_{\mathcal{A},\Pi}$

- $\mathcal{A}$ is given pk before choosing m_0, m_1



Security of Encryption

$\Pi := \langle \mathrm{Gen}, \mathrm{Enc}, \mathrm{Dec} \rangle$ has *indistinguishable encryptions in the presence of eavesdroppers* if $\forall$ PPT $\mathcal{A}$, $\exists$ negl. ϵ :

$$\Pr[\mathsf{PubK}^{\mathsf{eav}}_{\mathcal{A},\Pi}(n) = 1] = \frac{1}{2} + \epsilon(n)$$

Security of Encryption

Chosen-plaintext security

Given $\Pi := \langle \mathrm{Gen}, \mathrm{Enc}, \mathrm{Dec} \rangle$, and adversary $\mathcal{A}$, define the following experiment $\mathrm{PubK}^{\mathrm{cpa}}_{\mathcal{A},\Pi}(n)$:

1. Select $(pk, sk) \leftarrow \mathrm{Gen}(1^n)$
2. $\mathcal{A}(pk)$ is given oracle access to $\mathrm{Enc}_{pk}(\cdot)$
3. $\mathcal{A}$ outputs $m_0, m_1 \in \mathcal{M}$
4. Choose $b \leftarrow \{0, 1\}$ and send $\mathrm{Enc}_{pk}(m_b)$ to $\mathcal{A}$
5. $\mathcal{A}$ is again given oracle access to $\mathrm{Enc}_{pk}(\cdot)$
6. $\mathcal{A}$ outputs b'
7. Define $\mathrm{PubK}^{\mathrm{cpa}}_{\mathcal{A},\Pi}(n) := 1$ iff $b = b'$

Security against CPA

$\Pi := \langle \mathrm{Gen}, \mathrm{Enc}, \mathrm{Dec} \rangle$ has *indistinguishable encryption under a chosen-plaintext attack* if $\forall$ PPT $\mathcal{A}$, $\exists$ negl. ϵ :

$$\Pr[\mathsf{PubK}^{\mathsf{cpa}}_{\mathcal{A},\Pi}(n) = 1] \leq \frac{1}{2} + \epsilon(n)$$

Quiz 1

What is the relationship between $\mathrm{PubK}^{\mathrm{eav}}_{\mathcal{A},\Pi}(n)$ and $\mathrm{PubK}^{\mathrm{cpa}}_{\mathcal{A},\Pi}(n)$?

1. It is **harder** to win the $\mathrm{PubK}^{\mathrm{eav}}_{\mathcal{A},\Pi}(n)$ game than to win the $\mathrm{PubK}^{\mathrm{cpa}}_{\mathcal{A},\Pi}(n)$ game.
2. It is **easier** to win the $\mathrm{PubK}^{\mathrm{eav}}_{\mathcal{A},\Pi}(n)$ game than to win the $\mathrm{PubK}^{\mathrm{cpa}}_{\mathcal{A},\Pi}(n)$ game.
3. These two games are just as easy/difficult to win

Answer: They are **equivalent**!

Quiz 2

Could we build a perfectly secure public key encryption scheme?

1. Maybe, this is an open research problem
2. No: since the private key has a finite length, an adversary can take a challenge ciphertext and try to decrypt it with all possible private keys until he gets a meaningful plaintext
3. No: since the adversary has the public key, he can take a challenge ciphertext c and encrypt the two challenge messages with all possible random coins until it gets c
4. No: since the adversary has the public key, he can run the key generation algorithm with all possible random coins until he gets pk and the matching sk

Secure multiple encryption

Define the multiple message eavesdropping experiment $\mathsf{PubK}^{\mathsf{mult}}_{\mathcal{A},\Pi}(n)$:

1. Select $(pk, sk) \leftarrow \mathrm{Gen}(1^n)$
2. $\mathcal{A}(pk)$ outputs $M_0 = (m_0^1, \ldots, m_0^t), M_1 = (m_1^1, \ldots, m_1^t)$
3. Choose $b \leftarrow \{0,1\}$, send $(\mathrm{Enc}_{pk}(m_b^1), \ldots, \mathrm{Enc}_k(m_b^t))$ to $\mathcal{A}$
4. $\mathcal{A}$ outputs b'
5. Define $\mathsf{PubK}^{\mathsf{mult}}_{\mathcal{A},\Pi}(n) := 1$ iff $b = b'$

Secure multiple encryption

$\Pi := \langle \mathrm{Gen}, \mathrm{Enc}, \mathrm{Dec} \rangle$ has *indistinguishable multiple encryption in the presence of eavesdroppers* if

$\forall$ PPT $\mathcal{A}$, $\exists$ negl. ϵ :

$$\Pr[\mathsf{PubK}^{\mathsf{mult}}_{\mathcal{A},\Pi}(n) = 1] \leq \frac{1}{2} + \epsilon(n)$$

This property is equivalent to the first two. . .

$\rightarrow$ K&L, 1st edition, theorem 10.10, p.344

$\rightarrow$ K&L, 2nd edition, theorem 11.10, p.381

$\rightarrow$ K&L, 3rd edition, theorem 12.6, p.408

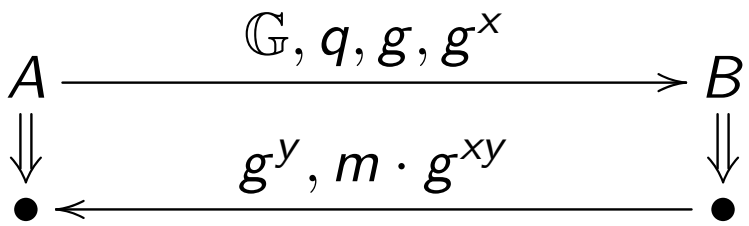


El Gamal Encryption

A CPA-secure encryption scheme: *ElGamal* (1985)

Ideas:

- use g^x as public key
- use g^{xy} to encrypt $m \in \mathbb{G}$:



ElGamal



ElGamal Encryption

A CPA-secure encryption scheme: *ElGamal* (1985)

$\mathrm{Gen}(1^n)$

- runs $\mathcal{G}$ to obtain $(\mathbb{G}, q, g)$
- selects $x \leftarrow \mathbb{Z}_q$, computes $h := g^x$
- $\langle pk, sk \rangle := \langle (\mathbb{G}, q, g, h), (\mathbb{G}, q, g, x) \rangle$

$\mathrm{Enc}_{pk}(m)$: message $m \in \mathbb{G}$ is encrypted as

- $y \leftarrow \mathbb{Z}_q$
- $\mathrm{Enc}_{pk}(m) := \langle g^y, m \cdot h^y \rangle$

$\mathrm{Dec}_{sk}(\langle c_1, c_2 \rangle) := c_2 / c_1^x$

Correctness: $$\frac{c_2}{c_1^x} = \frac{m \cdot h^y}{(g^y)^x} = \frac{m \cdot (g^x)^y}{g^{x \cdot y}} = m$$

ElGamal Security

Can we prove that ElGamal is CPA-secure based on the hardness of the DL problem w.r.t. $\mathcal{G}$?

1. Yes: if I can solve the DL problem, I can compute the secret key from the public key and decrypt
2. No: if I can compute the least significant bit of h^y given (g, h, g^y), then it is enough to break ElGamal, but not necessarily to solve DL

ElGamal Security

We need more than the DL assumption!

- It may be possible to compute h^y without solving the DL (We do not know how, but we cannot exclude it)
- We need h^y to be *completely* unpredictable, else parts of m may be leaked

This is actually true even for DH key agreement: if g^{xy} can be used as a key, then g^{xy} must be "as" a random key, not just hard to compute

Decisional Diffie-Hellman

Let $\mathrm{DDH}_{\mathcal{A},\mathcal{G}}(n)$ be the following experiment

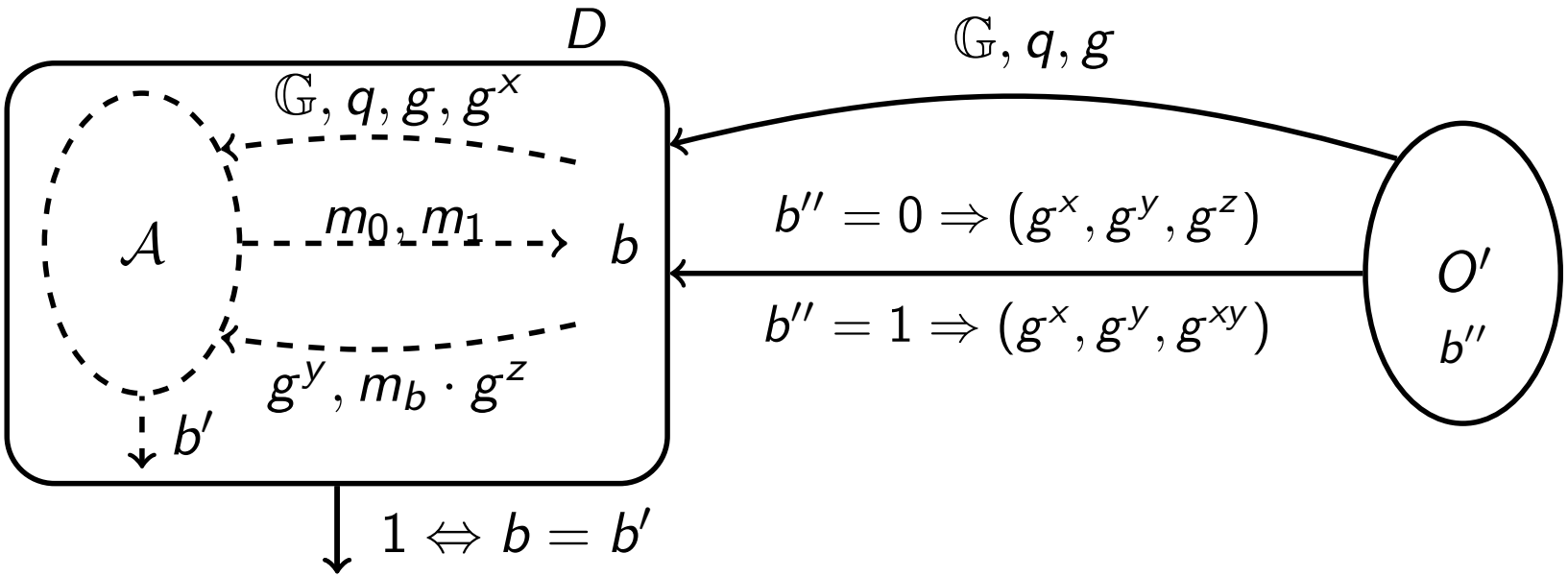
1. Run $\mathcal{G}(1^n)$ to obtain $(\mathbb{G}, q, g)$ where g generates the group $\mathbb{G}$ of order q, with $|q| = n$
2. Choose $(x, y, z) \xleftarrow{R} \mathbb{Z}_q^3$
3. Flip a coin $b \xleftarrow{R} \{0,1\}$, and set $h_1 := g^{x \cdot y}$ and $h_0 := g^z$
4. Set $b' \leftarrow \mathcal{A}\big(\mathbb{G}, q, g, (g^x, g^y, h_b)\big)$
5. $\mathrm{DDH}_{\mathcal{A},\mathcal{G}}(n) = 1 \Leftrightarrow b = b'$

The *decisional Diffie-Hellman problem* is hard relative to $\mathcal{G}$ if:
$\forall$ PPT $\mathcal{A}$, there is a negl. $\epsilon(n)$ s.t.:

$$\Pr[\mathrm{DDH}_{\mathcal{A},\mathcal{G}}(n) = 1] \leq \frac{1}{2} + \epsilon(n),$$

El Gamal Security

Indistinguishability of encryptions ($\Leftrightarrow$ CPA security)



Observe:

- If $b'' = 0$, $\Pr[D \text{ outputs } 1] = \frac{1}{2}$ (as $m_b \cdot g^z$ is random in $\mathbb{G}$)
- If $b'' = 1$, $\Pr[D \text{ outputs } 1] = \frac{1}{2} + \eta(n)$ (normal game)
- D distinguishes with Pr as $\mathcal{A} \Rightarrow$ safe under DDH

ElGamal Encryption

Is it important to encode m in $\mathbb{G}$?

Assume $\mathbb{G}$ is a cycle subgroup of $\mathbb{Z}_p^*$ of order q with $p = 2kq + 1$

- ElGamal public key g and h are generators of $\mathbb{G}$
- Encryption components $c_1 = g^y$ and h^y are ("random") in $\mathbb{G}$
- Under DDH, $c_2 = m \cdot h^y$ is like a one-time pad over $\mathbb{G}$
- If $m \notin \mathbb{G}$, it does not hold (like a too-short key in OTP)
- Worse, for $m_1 = -1 \bmod p$, $c_2 = -h^y$ has order $2q$ (not q)
- ... can be distinguished from the encryption of $m_0 = 1$

What if m is too large/complex to encode in $\mathbb{G}$?

- Use many ElGamal encryption (multi-encryption CPA security!)
- Less expensive solution? Hint: remember key agreement Solution: use a KDF function H to generate $k = H(h^y)$



DHIES – ISO/IEC 18033-2

Message can be any bitstring (with a mode of operation)

DHIES/ECIES ($\approx$ ISO/IEC 18033-2):

- Gen as in ElGamal, gives $\langle pk, sk\rangle := \langle(\mathbb{G}, q, g, h), x)\rangle$
- $\mathrm{ENC}_{pk}(m)$: pick $y \leftarrow \mathbb{Z}_q$, derive $k = H(h^y)$, return $\langle c_1, c_2\rangle = \langle g^y, \mathrm{Enc}_k(m)\rangle$ with a symmetric Enc
- $\mathrm{DEC}_{sk}(c_1, c_2)$: compute $k = H(c_1^x)$, return $\mathrm{Dec}_k(c_2)$

Proven to be CCA secure under reasonable assumptions

- Does it work in a more general sense?
- What about other groups or structure?

Security of Encryption

Chosen-ciphertext security

Given $\Pi := \langle \mathrm{Gen}, \mathrm{Enc}, \mathrm{Dec} \rangle$, and adversary $\mathcal{A}$, define the following experiment $\mathrm{PubK}^{\mathrm{cca}}_{\mathcal{A},\Pi}(n)$:

1. Select $(pk, sk) \leftarrow \mathrm{Gen}(1^n)$
2. $\mathcal{A}(pk)$ is given oracle access to $\mathrm{Dec}_{sk}(\cdot)$
3. $\mathcal{A}$ outputs $m_0, m_1 \in \mathcal{M}$
4. Choose $b \leftarrow \{0, 1\}$ and send $c^* = \mathrm{Enc}_{pk}(m_b)$ to $\mathcal{A}$
5. $\mathcal{A}$ is again given oracle access to $\mathrm{Dec}_{sk}(\cdot)$ but not for c^*
6. $\mathcal{A}$ outputs b'
7. Define $\mathrm{PubK}^{\mathrm{cpa}}_{\mathcal{A},\Pi}(n) := 1$ iff $b = b'$

Security against CCA

$\Pi := \langle \mathrm{Gen}, \mathrm{Enc}, \mathrm{Dec} \rangle$ has *indistinguishable encryption under a chosen-ciphertext attack* if $\forall$ PPT $\mathcal{A}$, $\exists$ negl. ϵ :

$$\Pr[\mathsf{PubK}^{\mathsf{cca}}_{\mathcal{A},\Pi}(n) = 1] \leq \frac{1}{2} + \epsilon(n)$$

Key-Encapsulation Mechanism

A KEM is a triple $\langle \mathrm{Gen}, \mathrm{Encaps}, \mathrm{Decaps} \rangle$ of PPT algos:

- Gen probabilistically selects $(pk, sk) \leftarrow \mathrm{Gen}(1^n)$
  pk/sk are the public/private key
- Encaps provides $(c, k) \leftarrow \mathrm{Encaps}(pk)$
- Decaps provides $k := \mathrm{Decaps}_{sk}(c)$

s.t., $\exists$ negl. $\epsilon : \forall n$, $(pk, sk) \leftarrow \mathrm{Gen}(1^n)$:

$$\Pr[\mathrm{Decaps}_{sk}(c) \neq k | (c, k) \leftarrow \mathrm{Encaps}(pk)] < \epsilon(n)$$

A DEM, for data-encapsulation mechanism, is a symmetric encryption

Security of KEM

Chosen-plaintext/ciphertext security

Given $\Pi := \langle \mathrm{Gen}, \mathrm{Encaps}, \mathrm{Decaps} \rangle$, and adversary $\mathcal{A}$, define the following experiment $\mathrm{KEM}^{\mathrm{cpa}}_{\mathcal{A},\Pi}(n)/\mathrm{KEM}^{\mathrm{cca}}_{\mathcal{A},\Pi}(n)$:

1. Select $(pk, sk) \leftarrow \mathrm{Gen}(1^n)$, $b \leftarrow \{0,1\}$ and $(c, k) \leftarrow \mathrm{Encaps}(pk)$
2. $\mathcal{A}(pk)$ is given oracle access to $\mathrm{Encaps}(\cdot)/\mathrm{Decaps}_{sk}(\cdot)$
3. If $b = 0$ set $k^* := k$, else $k^* \leftarrow \{0,1\}^n$, and return (c, k^*)
4. $\mathcal{A}(pk)$ is given oracle access to $\mathrm{Encaps}(\cdot)/\mathrm{Decaps}_{sk}(\cdot)$ not for c^*
5. $\mathcal{A}$ outputs b'
6. Define $\mathrm{KEM}^{\mathrm{cpa}}_{\mathcal{A},\Pi}(n) := 1/\mathrm{KEM}^{\mathrm{cca}}_{\mathcal{A},\Pi}(n) :=$ iff $b = b'$

Π is *chosen-plaintext/ciphertext secure* if $\forall$ PPT $\mathcal{A}$, $\exists$ negl. ϵ:

$$\Pr[\mathrm{KEM}^{\mathrm{cpa/cca}}_{\mathcal{A},\Pi}(n) = 1] \leq \frac{1}{2} + \epsilon(n)$$



Hybrid Encryption: KEM/DEM Paragdigm

Message can be any bitstring (with a mode of operation)
Let $\Pi := \langle \mathrm{Gen}, \mathrm{Encaps}, \mathrm{Decaps} \rangle$ be a KEM
Let $\Pi' := \langle \mathrm{Gen}', \mathrm{Enc}', \mathrm{Dec}' \rangle$ be a symmetric encryption scheme

The KEM/DEM $\Pi^* := \langle \mathrm{Gen}, \mathrm{Enc}, \mathrm{Dec} \rangle$ is the following PKE

- Gen run and output $(pk, sk) \leftarrow \mathrm{Gen}(1^n)$
- $\mathrm{Enc}_{pk}(m)$: computes $(c, k) \leftarrow \mathrm{Encaps}(pk)$ and $c' \leftarrow \mathrm{Enc}'_k(m)$, and output $\langle c, c' \rangle$
- $\mathrm{Dec}_{sk}(c, c')$: compute $k = \mathrm{Decaps}_{sk}(c)$, and return $\mathrm{Dec}'_k(c')$

Proven to be a CCA secure PKE as long as

- KEM is CCA-secure + DEM is CCA secure